

CYBER SECURE SOLUTIONS

Gestion des accès privilégiés

Type: politique_acces_privileges

Date: 3/30/2025
Référence: L'IAM
Destinataire: maxim

****POLITIQUE D'ACCÈS PRIVILÉGIÉS****

Domaine : Gestion des Identités et des Accès (IAM)

Destinataire : Maxim

Contact : Eddy MISSONI IDEMBI (Responsable Sécurité Informatique)

1. ****Objectif de la politique****

Cette politique vise à encadrer et sécuriser la gestion des accès privilégiés dans l'environnement informatique de l'entreprise. Les accès privilégiés représentent un risque accru en cas de compromission et nécessitent des contrôles renforcés pour garantir la confidentialité, l'intégrité et la disponibilité des systèmes critiques.

2. ****Contexte et problématique****

Dans le cadre de l'évolution des infrastructures de l'entreprise, plusieurs utilisateurs ont été identifiés comme ayant des droits d'accès élevés sur des systèmes sensibles, notamment :

- Les serveurs de production (Windows et Linux).
- Les bases de données critiques (Oracle, SQL Server).
- Les outils de gestion des identités (Active Directory, LDAP).
- Les plateformes SaaS utilisées pour les opérations métier sensibles.

Ces accès privilégiés sont nécessaires pour l'administration et la maintenance, mais exposent des vecteurs de menace importants, tels que :

- ****Elevated Privilege Exploitation**** : Un attaquant peut exploiter des privilèges excessifs pour exfiltrer des données ou perturber les services.
- ****Insider Threats**** : Un utilisateur interne peut abusivement modifier les configurations ou accéder à des données sensibles.
- ****Credential Theft**** : Le vol des identifiants administratifs peut ouvrir une porte d'accès aux systèmes critiques.

L'environnement actuel repose sur un modèle de gestion des accès où les droits sont octroyés directement dans les systèmes, parfois sans expiration automatique ou justification périodique. Il est donc impératif de mettre en place une politique stricte pour réduire ces risques.

3. ****Portée****

Cette politique s'applique à tous les utilisateurs, comptes de service et applications disposant d'un accès privilégié aux infrastructures de l'entreprise, incluant :

- Administrateurs systèmes et réseaux.
- Développeurs et DevOps ayant des droits sur les environnements de production.
- Comptes techniques et automatisés (service accounts).
- Fournisseurs ou partenaires externes ayant des accès temporaires.

4. ****Principes clés****

Les contrôles suivants devront être respectés :

1. ****Principe du moindre privilège (Least Privilege)**** : Les utilisateurs doivent disposer uniquement des droits nécessaires à l'exécution de leurs tâches.
2. ****Gestion des comptes privilégiés**** : Les comptes administratifs doivent être séparés des comptes utilisateurs standards.
3. ****Authentification renforcée**** : Les accès administratifs doivent nécessiter une authentification multi-facteurs (MFA).
4. ****Journalisation obligatoire**** : Toutes les activités des comptes privilégiés doivent être enregistrées dans des journaux sécurisés pour permettre un suivi et une analyse approfondie.
5. ****Revue périodique**** : Les accès privilégiés doivent être audités régulièrement pour identifier et supprimer les droits obsolètes.

5. ****Éléments techniques présents dans l'environnement****

- ****Gestionnaire d'accès**** : CyberArk est actuellement utilisé pour le stockage et la rotation des mots de passe des comptes privilégiés.
- ****Outil de surveillance**** : Splunk est configuré pour collecter les journaux des activités des comptes privilégiés.
- ****Système de contrôle d'accès**** : Active Directory utilise des groupes d'accès, mais une cartographie complète des privilèges n'a pas été réalisée.
- ****Authentification**** : La solution MFA est partiellement déployée sur les comptes administratifs.

6. ****Problème identifié****

Une analyse récente a révélé les points faibles suivants :

- ****Absence de rotation automatisée des mots de passe**** pour certains comptes techniques.
- ****Privilèges permanents**** attribués à des comptes qui n'ont pas été utilisés depuis plus de 90 jours.
- ****Accès partagé**** à un même compte privilégié entre plusieurs utilisateurs.
- ****Manque de visibilité**** sur les activités des administrateurs externes lors de leurs connexions aux systèmes critiques.

7. ****Questions pour réflexion****

- Quelles étapes techniques sont nécessaires pour implémenter un modèle de gestion des droits basé sur des rôles (RBAC) ?
- Comment gérer les accès temporaires pour les fournisseurs externes sans compromettre la

sécurité ?

- Quels outils ou processus pourraient être ajoutés pour renforcer la surveillance des activités des comptes privilégiés ?
- Existe-t-il des risques liés à l'usage des comptes administratifs partagés ?

8. ****Suivi et contact****

Pour toute question relative à cette politique ou pour signaler un problème lié aux accès privilégiés, veuillez contacter :

****Eddy MISSONI IDEMBI****

Responsable Sécurité Informatique

Email : eddy.missoni@entreprise.com

Téléphone : +33 1 45 67 89 10

Fin du document.

